

UNIT 1

1. Introduction:

- **Terminology:** The basic terms and vocabulary used in ethical hacking (e.g., hacker, penetration testing, vulnerability, etc.).
- **Hacking Technology Types:** Different types of hacking methods used by hackers, such as social engineering, network attacks, and web application vulnerabilities.
- **Ethical Hacking Phases:** The stages that ethical hackers follow while conducting penetration testing (e.g., planning, scanning, exploitation, reporting).
- **Hactivism:** When hackers use their skills for political or social causes, often to protest or spread a message (e.g., hacking to support freedom of speech).
- **Hacker Classes:** Hackers are usually classified based on their actions and goals:
 - **Black Hat Hackers:** Malicious hackers who exploit vulnerabilities for personal or financial gain.
 - **White Hat Hackers:** Ethical hackers who help identify and fix vulnerabilities.
 - **Grey Hat Hackers:** Hackers who may breach security but without malicious intent, often to expose flaws.
- **Skills Required for an Ethical Hacker:** Ethical hackers need knowledge in programming, networking, operating systems (especially Linux), security protocols, and tools like Nmap and Wireshark.
- **Vulnerability Research:** Identifying weaknesses in systems, networks, or software that could be exploited by malicious hackers.
- **Ways to Conduct Ethical Hacking:** Different ways of carrying out penetration tests, like using automated tools or manual methods to find security flaws.

2. Footprinting:

- **Definition:** Footprinting is the process of gathering information about a target system or network to find potential vulnerabilities.
- **Information Gathering Methodology:** The process used by ethical hackers to collect data about the target, including domain names, IP addresses, and other details that can be used for further attacks.
- **Competitive Intelligence:** Gathering information about competitors in a legal and ethical manner, which can also help identify potential security risks.
- **DNS Enumeration:** Gathering information about a domain's DNS (Domain Name System) records to learn more about a network or system.
- **Whois and ARIN Lookups:** Whois helps find out the owner of a domain, and ARIN provides info on IP addresses (like who owns the IP address).
- **Types of DNS Records:** These records contain information about domains, like IP addresses, mail servers, and name servers.
- **Traceroute in Footprinting:** A tool used to track the path data takes from one network to another, helping you map out the network structure.
- **E-Mail Tracking:** Identifying the source of an email and potentially gaining information about the sender.

3. Social Engineering:

- **Common Types of Attacks:** Social engineering attacks involve manipulating people into giving away sensitive information. Common types include:
 - **Phishing:** Fraudulent emails or messages tricking people into giving personal information.
 - **Pretexting:** Pretending to be someone trustworthy to gain access to information.
 - **Baiting:** Offering something enticing (like free software) to trick users into compromising their system.
 - **Quizzes or Surveys:** Gaining personal information through fake surveys or questionnaires.

4. Scanning and Enumeration:

- **Port Scanning:** Checking which ports on a network are open, which can indicate available services or vulnerabilities.
- **Network Scanning:** Scanning a network to identify devices, services, and potential security weaknesses.
- **Vulnerability Scanning:** Using tools to find weaknesses in a network or system that could be exploited by hackers.
- **CEH Scanning Methodology:** The specific approach used by Certified Ethical Hackers to perform network scanning in an organized way.
- **Ping Sweep Techniques:** Identifying which devices on a network are alive (responsive) by sending ICMP packets to each device.
- **Nmap Command Switches:** Nmap is a powerful tool for network scanning, and it uses different commands (e.g., `-ss` for SYN scan) to detect open ports, services, etc.
- **SYN Scan, Stealth Scan, XMAS Scan, NULL Scan, IDLE Scan, FIN Scan:** Different types of scanning techniques used by hackers and ethical hackers to identify open ports or services, each with varying levels of stealth or effectiveness.
- **Anonymizers:** Tools or techniques used to hide the hacker's identity or location during scanning or attacks (e.g., using VPNs or proxies).
- **HTTP Tunneling Techniques:** Methods used to tunnel other types of traffic (like malicious data) through the HTTP protocol to avoid detection.
- **IP Spoofing Techniques:** Changing the source IP address in a packet to make it appear as though it came from a trusted source, typically used in DDoS attacks.
- **SNMP Enumeration:** Gathering information using Simple Network Management Protocol (SNMP) to learn more about a network or its devices.
- **Steps Involved in Enumeration:** The process of actively collecting information about a target, like user accounts, groups, and network resources.

UNIT 2

1. System Hacking:

- **Password-Cracking Techniques:** Methods used to break or guess a password. Some techniques include:
 - **Brute Force Attack:** Trying all possible combinations until the correct password is found.

- **Dictionary Attack:** Trying a list of common passwords or words from a dictionary.
- **Rainbow Table Attack:** Using precomputed tables to reverse hash values and find passwords.
- **Types of Passwords:** These refer to different forms of password protection, such as:
 - **Static Passwords:** Regular passwords that don't change.
 - **Dynamic Passwords:** Passwords that change, like those sent via SMS (One-Time Passwords or OTPs).
 - **Biometric Passwords:** Passwords based on unique physical traits, such as fingerprints.
- **Keyloggers and Other Spyware Technologies:** Programs that secretly record keystrokes on a computer, allowing attackers to steal passwords, credit card numbers, or other sensitive data.
- **Escalating Privileges:** When a hacker gains more control over a system than originally allowed. For example, moving from a regular user to an administrator or root user to execute commands.
- **Rootkits:** Malicious software that hides its presence and allows a hacker to control a computer system remotely without detection.

2. Sniffers:

- **Protocols Susceptible to Sniffing:** Some communication protocols are not encrypted, making it easy for hackers to eavesdrop and capture sensitive data. These include HTTP, FTP, and Telnet.
- **Active and Passive Sniffing:**
 - **Active Sniffing:** Actively sending data packets onto the network to gather information (e.g., ARP poisoning).
 - **Passive Sniffing:** Listening to the network traffic without sending data, quietly capturing packets.
- **ARP Poisoning:** A technique where attackers send fake ARP (Address Resolution Protocol) messages on a network, linking their MAC address to another device's IP address, allowing them to intercept data.
- **MAC Flooding:** Overloading a switch's MAC address table with fake addresses, causing it to send traffic to all ports (like a hub) and allowing the attacker to capture data.
- **DNS Spoofing Techniques:** Manipulating DNS (Domain Name System) records to redirect a victim's browser to a malicious site instead of the legitimate one.
- **Sniffing Countermeasures:** Preventive measures to stop sniffing attacks, such as:
 - Encrypting data using SSL/TLS.
 - Using VPNs (Virtual Private Networks) to protect data.
 - Switching to secure protocols like HTTPS, SSH, etc.

3. Denial of Service (DoS):

- **Types of DoS Attacks:** DoS attacks aim to overwhelm a target system or network so it cannot function properly. Common types:
 - **Flooding Attacks:** Overloading a network or system with massive amounts of traffic.
 - **Amplification Attacks:** Sending small requests to a service that causes a large amount of traffic to be sent to the victim.

- **Working of DoS Attacks:** The goal is to prevent legitimate users from accessing services by causing the target system to crash or become too slow.
- **BOTs/BOTNETs:** A **bot** is a device infected with malware that can be controlled remotely. A **botnet** is a network of infected devices used for DoS attacks.
- **“Smurf” Attack:** A DoS attack where a hacker sends a ping request to a network's broadcast address, which then sends replies to the victim, overwhelming it.
- **“SYN” Flooding:** A DoS attack that exploits the three-way handshake of the TCP protocol by sending a flood of SYN requests, causing the target system to become unresponsive.
- **DoS/DDoS Countermeasures:**
 - Using firewalls and intrusion detection systems (IDS).
 - Configuring rate-limiting and load balancing.
 - Using services like Cloudflare to absorb large amounts of attack traffic.

4. Session Hijacking:

- **Spoofing vs. Hijacking:**
 - **Spoofing:** Pretending to be someone else to gain unauthorized access.
 - **Hijacking:** Taking over an active session between a user and a server (e.g., stealing a session cookie to impersonate the user).
- **Types of Session Hijacking:**
 - **Active Hijacking:** The attacker actively interferes with the session by injecting commands or altering data.
 - **Passive Hijacking:** The attacker only monitors the session and captures sensitive data without modifying it.
- **Sequence Prediction:** The attacker tries to guess the sequence number used in TCP communication to predict the session ID.
- **Steps:** The process involves:
 1. **Sniffing** the session data.
 2. **Hijacking** the session by stealing session cookies or credentials.
 3. **Injecting commands** or using the hijacked session.
- **Prevention:** To prevent session hijacking, secure connections should be used (e.g., HTTPS), and techniques like session expiration, random session IDs, and encryption should be applied.

5. Hacking Web Servers:

- **Web Server Vulnerabilities:** Web servers can have weaknesses that attackers exploit to gain unauthorized access. Examples include outdated software, weak authentication, and improper configurations.
- **Attacks Against Web Servers:**
 - **SQL Injection:** Attacking the backend database by inserting malicious SQL code through web forms.
 - **Cross-Site Scripting (XSS):** Inserting malicious scripts into web pages that execute on other users' browsers.
 - **Cross-Site Request Forgery (CSRF):** Forcing a user to perform unwanted actions on a website they're authenticated on.
- **Patch Management Techniques:** Regularly updating and patching web server software to fix vulnerabilities is critical to securing the server.

- **Web Server Hardening:** Securing a web server by:
 - Configuring proper file and directory permissions.
 - Disabling unused services.
 - Using firewalls and secure communication (e.g., HTTPS).
 - Regularly updating and applying security patches.

UNIT 3

1. Web Application Vulnerabilities:

- **Web Application Hacking:** Web applications (like online stores, forums, etc.) are often targeted by hackers because they can be accessed remotely. Hackers exploit vulnerabilities in the application to steal data or perform malicious actions (e.g., SQL Injection, Cross-Site Scripting (XSS)).
- **Web Application Threats:** These are potential dangers that web applications face, such as:
 - **SQL Injection (SQLi):** Attackers insert malicious SQL queries into input fields (like login forms) to manipulate the database.
 - **Cross-Site Scripting (XSS):** Hackers inject malicious scripts into web pages, which execute on the browsers of users visiting the page.
 - **Cross-Site Request Forgery (CSRF):** Attackers trick a user into performing unwanted actions on a website where they are authenticated.
- **Google Hacking:** Google Hacking involves using advanced search operators (like `site:`, `inurl:`, `intitle:`) to find vulnerable web applications or files that should not be publicly accessible (e.g., passwords, configuration files).
- **Countermeasures:**
 - Input validation to prevent malicious inputs.
 - Web application firewalls (WAF) to filter out malicious traffic.
 - Regular updates and patches to fix vulnerabilities.

2. Web-Based Password Cracking Techniques:

- **Authentication Types:**
 - **Basic Authentication:** A simple method where the user provides a username and password.
 - **Digest Authentication:** An encrypted form of authentication that's more secure than basic authentication.
 - **Two-Factor Authentication (2FA):** Uses two methods (like a password and a code sent to your phone) to ensure security.
- **Password Crackers:** Tools used by hackers to guess or crack passwords. Common methods include:
 - **Brute Force Attack:** Trying all possible combinations of passwords until the correct one is found.
 - **Dictionary Attack:** Using a list of common words or password combinations.

- **Rainbow Tables:** Precomputed tables of password hashes used to reverse-engineer password hashes faster.
- **Countermeasures:**
 - Using strong, complex passwords (e.g., mixing letters, numbers, and symbols).
 - Implementing rate-limiting to slow down password-guessing attacks.
 - Enforcing multi-factor authentication.

3. SQL Injection:

- **Steps in SQL Injection:**
 1. **Identify a vulnerable input field** (like a login form or search bar).
 2. **Inject malicious SQL code** that manipulates the SQL query (e.g., ' OR 1=1; --).
 3. **Gain unauthorized access** to the database or execute malicious commands.
- **SQL Server Vulnerabilities:** Weak input validation, lack of parameterized queries, and improper handling of user input can allow attackers to execute SQL injection.
- **Countermeasures:**
 - Using parameterized queries or prepared statements to prevent SQL injection.
 - Input validation to ensure only expected data is accepted.
 - Using web application firewalls (WAF) to detect and block SQL injection attempts.

4. Buffer Overflows:

- **Types of Buffer Overflows:**
 - **Stack-Based Buffer Overflow:** This occurs when data is written to a buffer on the stack (temporary memory), which can overwrite important memory and allow attackers to inject malicious code.
 - **Heap-Based Buffer Overflow:** This involves the heap (long-term memory) where the attacker exploits memory allocation to execute malicious code.
- **Mutation Techniques:** These techniques are used to modify the payload (malicious code) to evade detection by security mechanisms (e.g., anti-virus software).

5. Wireless Hacking:

- **WEP (Wired Equivalent Privacy):** An old encryption standard for wireless networks that is insecure and vulnerable to attacks.
- **WPA (Wi-Fi Protected Access):** A more secure encryption standard that replaced WEP, though still vulnerable to some attacks (e.g., WPA2 and WPA3 are more secure).
- **Authentication Mechanisms:**
 - **WPA/WPA2-PSK (Pre-shared Key):** Uses a shared password for authentication.
 - **WPA Enterprise:** Uses an authentication server for more secure connections.
- **Cracking Techniques:** Attackers can use tools like **Aircrack-ng** to crack WEP and WPA passwords by capturing and analyzing network traffic.
- **Wireless Sniffers:** Tools like **Wireshark** are used to capture and analyze network packets to find weaknesses.

- **Rogue Access Points:** Attackers can set up fake access points with the same name as a legitimate one to trick users into connecting, allowing the attacker to intercept data.
- **Wireless Hacking Techniques:** Common techniques include sniffing (capturing data), de-authentication attacks (disconnecting users to capture their credentials), and password cracking.
- **Securing Wireless Networks:**
 - Use strong encryption (e.g., WPA2).
 - Disable WPS (Wi-Fi Protected Setup).
 - Change default router settings (e.g., SSID, password).
 - Use a VPN to encrypt internet traffic.

6. Penetration Testing Methodologies:

- **Methodologies:** The structured approach ethical hackers use to perform penetration testing. Common methodologies include:
 - **OWASP Testing Guide** for web applications.
 - **PTES (Penetration Testing Execution Standard)** for overall testing.
- **Steps in Penetration Testing:**
 1. **Planning:** Define the scope, goals, and testing methods.
 2. **Reconnaissance (Footprinting):** Gather information about the target system.
 3. **Scanning and Enumeration:** Identify vulnerabilities and open ports.
 4. **Exploitation:** Attempt to exploit vulnerabilities.
 5. **Post-exploitation:** Maintain access and evaluate the impact of the breach.
 6. **Reporting:** Document findings and provide recommendations.
- **Automated Tools:** Tools like **Nmap**, **Metasploit**, **Burp Suite**, and **Wireshark** automate parts of the penetration testing process, such as scanning, exploitation, and sniffing.
- **Pen-Test Deliverables:** The final report that contains:
 - **Executive Summary:** A high-level overview of findings.
 - **Technical Details:** In-depth analysis of vulnerabilities and how they were exploited.
 - **Risk Assessment:** A ranking of vulnerabilities by risk level (e.g., low, medium, high).
 - **Recommendations:** Steps for fixing or mitigating the vulnerabilities.

QUESTION BANK

UNIT 1

1) What is hacking? Also, explain what are hacker classes in short.

- **Hacking:** Hacking is the process of identifying and exploiting weaknesses or vulnerabilities in a system, device, or network to gain unauthorized access, typically for malicious purposes or for improving security.
 - **Hacker Classes:**
 1. **White Hat Hackers (Ethical Hackers):** These hackers use their skills to improve system security by identifying and fixing vulnerabilities.
 2. **Black Hat Hackers:** Malicious hackers who exploit system vulnerabilities for personal gain or to cause damage.
 3. **Grey Hat Hackers:** Hackers who operate between legal and illegal activities, often identifying vulnerabilities without malicious intent but without proper authorization.
 4. **Blue Hat Hackers:** Hired to test a system's security before its release, often as part of a bug bounty program.
 5. **Script Kiddies:** Inexperienced hackers who use pre-written scripts or tools to perform attacks without understanding how they work.
-

2) Explain the types of Ethical Hacking.

- **Black Box Testing:** Hackers test the system without prior knowledge of its internal workings, simulating a real-world attack.
 - **White Box Testing:** Hackers have complete knowledge of the system's source code, architecture, and configurations.
 - **Grey Box Testing:** Hackers have partial knowledge, which simulates an insider threat, with both user-level and technical access.
-

3) Explain Hacking Technology and its types in detail.

- **Hacking Technology:** Refers to tools, methods, and techniques used by hackers to exploit vulnerabilities.
 - **Malware:** Software designed to damage or exploit systems (e.g., viruses, worms, ransomware).
 - **Social Engineering:** Manipulating individuals to divulge confidential information (e.g., phishing, baiting).
 - **Denial of Service (DoS):** Overloading a target system with traffic to make it unavailable.
 - **Exploitation:** Using a system's vulnerabilities to gain unauthorized access.
 - **Types of Hacking Technology:**
 1. **Keyloggers:** Programs that record keystrokes.
 2. **Rootkits:** Tools used to hide activities or malware in a system.
 3. **Exploits:** Code that takes advantage of system vulnerabilities.
 4. **Backdoors:** Secret methods to access a system without authorization.
-

4) What are the phases to understand Ethical Hacking? Explain it in detail.

1. **Reconnaissance (Information Gathering):** Collecting information about the target system, network, or individuals. It can be **active** (direct interaction) or **passive** (gathering from public sources).
 2. **Scanning:** Identifying open ports, services, and vulnerabilities through scanning tools like Nmap.
 3. **Gaining Access:** Exploiting vulnerabilities or weaknesses to access the system.
 4. **Maintaining Access:** Installing backdoors or other tools to maintain access to the system even after the attack is detected.
 5. **Covering Tracks:** Removing traces of the attack to avoid detection by administrators or security systems.
-

5) Define Hactivism and explain ways to manifest it.

- **Hactivism:** The act of hacking to promote political, social, or environmental causes. It uses digital tools to advance a cause or draw attention to issues.
 - **Ways to manifest Hactivism:**
 - **Website Defacement:** Changing the content of a website to convey a political message.
 - **Denial of Service (DoS) Attacks:** Overloading websites with traffic to disrupt access.
 - **Leaks:** Publishing confidential documents to expose wrongdoing.
-

6) Explain any five hacker classes.

1. **White Hat Hackers:** Ethical hackers who identify vulnerabilities and fix them to improve security.
 2. **Black Hat Hackers:** Malicious hackers who exploit vulnerabilities for personal gain or to cause damage.
 3. **Grey Hat Hackers:** Hackers who may break laws but generally do not intend harm, often identifying vulnerabilities without authorization.
 4. **Script Kiddies:** Inexperienced hackers who rely on pre-written tools or scripts to perform attacks.
 5. **Blue Hat Hackers:** Often hired to test the security of a system and fix vulnerabilities before the product is released.
-

7) What are the skills required for becoming an Ethical Hacker?

- **Technical Skills:**
 - Networking (TCP/IP, DNS, HTTP)
 - Operating Systems (Linux, Windows, MacOS)
 - Programming (Python, C++, JavaScript)
 - Web Technologies (HTML, CSS, JavaScript, SQL)
 - Cryptography
- **Analytical Skills:** Ability to think critically and solve complex problems.
- **Familiarity with Security Tools:** Tools like Wireshark, Nmap, Metasploit, Burp Suite.

- **Ethics and Legal Knowledge:** Understanding of laws related to cybersecurity and hacking.
-

8) Define vulnerability research and several key.

- **Vulnerability Research:** The process of discovering, analyzing, and understanding system vulnerabilities. It involves reverse engineering software, scanning systems, and examining code to find weaknesses.
 - **Key Steps:**
 - **Identifying Vulnerabilities:** Using tools or manual methods to find security holes.
 - **Analyzing Vulnerabilities:** Understanding how an exploit could work.
 - **Testing the Exploit:** Verifying if the vulnerability is exploitable.
-

9) What are the ways to conduct Ethical Hacking?

- **Penetration Testing (Pen Testing):** Simulating an attack to identify vulnerabilities.
 - **Vulnerability Assessment:** Identifying and prioritizing vulnerabilities without exploiting them.
 - **Red Teaming:** A full-scale simulated cyber attack to test defense mechanisms.
-

10) Define Footprinting and its types.

- **Footprinting:** The process of gathering information about a target system or network to find possible weaknesses. It can be done **actively** (interacting with the target system) or **passively** (gathering information from public sources).
 - **Types:**
 - **Passive Footprinting:** Gathering information without interacting with the target (e.g., WHOIS searches, DNS lookups).
 - **Active Footprinting:** Directly interacting with the target (e.g., port scanning, ping sweeps).
-

11) Explain the methods to perform Information Gathering.

- **Search Engines:** Using Google to search for valuable information.
 - **Social Media:** Extracting information from social platforms (LinkedIn, Facebook).
 - **WHOIS Lookup:** Finding domain registration details.
 - **DNS Queries:** Extracting DNS records to understand the network.
 - **Shodan:** A search engine for finding devices connected to the internet.
-

12) What are Competitive Intelligence in Ethical Hacking?

- **Competitive Intelligence (CI):** Gathering and analyzing publicly available information about competitors. In ethical hacking, CI helps understand the vulnerabilities of competing companies or individuals in the cybersecurity space.
-

13) Write a short note on DNS Enumeration.

- **DNS Enumeration** is the process of querying DNS records to gather information about a target domain, such as IP addresses, subdomains, and mail servers, which can be used for further attacks or security testing.
-

14) Explain WHOIS and ARIN Lookups in detail.

- **WHOIS Lookup:** A query to a database that provides information about domain names, IP address ownership, and the identity of the domain registrants.
 - **ARIN Lookup:** The American Registry for Internet Numbers (ARIN) provides information on the allocation of IP addresses in North America, which helps track the ownership of IP addresses.
-

15) What are the types of DNS Records in Ethical Hacking?

- **A Record:** Maps a domain name to an IP address.
 - **MX Record:** Identifies mail servers for a domain.
 - **NS Record:** Indicates the authoritative DNS servers for a domain.
 - **CNAME Record:** Alias of one domain to another domain.
-

16) What is Traceroute in Footprinting?

- **Traceroute** is a network diagnostic tool used to trace the path that packets take to reach a destination. It helps identify the network infrastructure between the attacker and the target.
-

17) Define E-mail Tracking and explain its working.

- **Email Tracking** allows the sender to track when an email is opened. This is achieved by embedding a small, invisible image or a special link in the email that notifies the sender when it is accessed.
-

18) Explain the following attacks in detail:

- **a) Key Stroke Logging:** Software or hardware that records every keystroke a user types.
- **b) Denial of Service (DoS) Attack:** Overloading a target system with requests to make it unavailable.
- **c) Watering Hole Attack:** Infecting a website that is frequently visited by the target, allowing the attacker to spread malware.
- **d) Brute Force Attack:** Trying every possible combination to guess a password.
- **e) Phishing and Fake WAP:** Phishing is deceiving individuals into providing sensitive information, while Fake WAP involves setting up a malicious Wi-Fi hotspot to capture data.

OR

- **a) Eavesdropping Attack:** Listening in on communications without authorization.
 - **b) Man-in-the-Middle Attack:** Intercepting and altering communication between two parties.
 - **c) Session Hijacking:** Taking control of a user's active session.
 - **d) Clickjacking:** Tricking users into clicking on hidden buttons or links.
 - **e) Cookie Theft:** Stealing session cookies to impersonate a user.
-

19) What is scanning? Explain Port Scanning in detail.

- **Scanning:** Identifying open ports, services, and vulnerabilities in a target system.
 - **Port Scanning:** Involves checking which ports on a target system are open and listening for communication. It helps attackers identify potential entry points.
-

20) Define Port Scanning with an example.

- **Port Scanning** involves probing a system for open ports. Example: Using Nmap to scan a target's IP address to find open ports (e.g., TCP 80 for HTTP).
-

21) Write a brief note on Network Scanning.

- **Network Scanning** involves mapping out a network's devices, identifying open ports, and gathering details about network infrastructure using tools like Nmap.
-

22) Explain Vulnerability Scanning in detail.

- **Vulnerability Scanning** involves using automated tools to identify weaknesses in systems, networks, or applications. This helps administrators patch vulnerabilities before they are exploited.
-

23) Explain CEH Scanning Methodology in brief.

- **CEH Scanning Methodology:** The Certified Ethical Hacker (CEH) scanning methodology involves planning, conducting, and reporting on vulnerability scans, including gathering information, scanning systems, analyzing findings, and making recommendations for security improvements.
-

24) What are the Ping Sweep Techniques and define its approaches?

- **Ping Sweep:** A technique used to identify live systems on a network by sending ICMP Echo requests (ping). If a system responds, it indicates that the system is active.
-

25) What are the Nmap Command Switches?

- **Nmap Command Switches:**
 - **-sP:** Ping scan (host discovery).
 - **-p:** Specify a port range.
 - **-sT:** TCP connect scan.
 - **-O:** OS detection.
 - **-A:** Enable OS detection, version detection, script scanning, and traceroute.
-

26) Explain how SYN is used to transfer the connection in Ethical Hacking.

- **SYN Scan:** The hacker sends a SYN request to a target to initiate a connection. If the target responds with SYN-ACK, it means the port is open.
-

27) Define Stealth in Ethical Hacking.

- **Stealth:** The practice of performing actions on a target system without being detected, often by using techniques like SYN scanning, decoy scanning, and covering tracks.
-

28) Explain how XMAS Scanning Techniques are used in Ethical Hacking.

- **XMAS Scanning:** Involves sending packets with the FIN, URG, and PSF flags set, which are unusual in a normal TCP connection. This technique is used to bypass firewalls and detection systems.
-

29) What is the term NULL defines in Ethical Hacking?

- **NULL Scan:** A scan where no flags are set in the TCP header, often used to avoid detection by firewalls. If a target system responds, it usually indicates an open port.
-

30) Explain the role of IDLE Scan in Ethical Hacking.

- **IDLE Scan:** A stealth scanning technique where the attacker uses a third-party system (idle) to send packets to the target system, making it difficult to trace the attacker.
-

31) Explain in FIN scans and its role in Ethical Hacking.

- **FIN Scan:** A scan that sends TCP packets with the FIN flag set. It is often used to bypass firewalls and intrusion detection systems, as legitimate systems don't typically send FIN packets unless they are terminating a connection.
-

32) What are the anonymizers in Ethical Hacking?

- **Anonymizers:** Tools used to hide the real identity of the hacker. Examples include proxies, Tor, and VPNs that allow hackers to mask their IP addresses during an attack.
-

33) What are the HTTP Tunneling Techniques in Ethical Hacking?

- **HTTP Tunneling:** Techniques used to encapsulate other protocols (such as FTP or SSH) within HTTP, allowing them to bypass firewalls or filters that block other protocols.
-

34) What are the IP Spoofing Techniques in Ethical Hacking?

- **IP Spoofing:** Technique used to send packets with a fake source IP address to mislead the target into believing the request is from a trusted source.
-

35) Explain SNMP Enumeration in detail.

- **SNMP Enumeration** is the process of gathering information from a device that uses the Simple Network Management Protocol (SNMP), such as router configurations, network devices, and server details.
-

36) What are the steps involved in Enumeration?

1. **Identify Target:** Use techniques like DNS queries or WHOIS to identify the target system.
2. **Scan the Network:** Use network scanning tools to discover live hosts and services.
3. **Enumerate Services:** Gather detailed information on open ports, services, and their versions.
4. **Exploit Weaknesses:** Use the information gathered to exploit vulnerabilities.

UNIT 2

1. Explain password hacking techniques.

Password hacking techniques involve methods used by attackers to gain unauthorized access to password-protected systems. These techniques include:

- **Brute Force Attack:** Trying every possible combination of characters to guess the correct password.
 - **Dictionary Attack:** Using a predefined list (dictionary) of common passwords to guess the target's password.
 - **Rainbow Table Attack:** Using precomputed tables of password hashes and their corresponding plaintext values to quickly reverse password hashes.
 - **Keylogging:** Installing malicious software that records every keystroke entered by a user to capture passwords.
 - **Phishing:** Tricking the user into entering their password into a fake website or email link.
 - **Credential Stuffing:** Using previously stolen username/password pairs to attempt logging into other accounts.
-

2. List and explain different types of passwords used.

- **Simple Passwords:** Easy to remember but weak passwords (e.g., "password123").
 - **Complex Passwords:** Use a combination of letters, numbers, and special characters (e.g., "M\$1nG5o!").
 - **Passphrases:** Longer passwords made up of a sequence of words or phrases (e.g., "TheQuickBrownFoxJumps!").
 - **One-time Passwords (OTPs):** A password that is valid for only one login session or transaction.
 - **Biometric Passwords:** Use of biometric data like fingerprints, face recognition, or retina scans.
 - **Token-based Passwords:** Generated by a physical or software token (e.g., RSA SecurID, Google Authenticator).
-

3. Explain spyware technologies in detail.

- **Spyware:** Malicious software designed to secretly monitor and collect user activity or personal information without the user's consent.

- **Types of Spyware:**
 1. **Adware:** Displays unwanted advertisements to the user.
 2. **Keyloggers:** Records every keystroke to steal sensitive information such as usernames and passwords.
 3. **Tracking Cookies:** Tracks browsing activity to build a user profile for targeted advertising.
 4. **Trojan Horses:** Malicious programs disguised as legitimate software, used to steal data or gain unauthorized access.
 - **Working of Spyware:** Spyware can be installed via malicious websites, email attachments, or bundled with software downloads. Once installed, it silently runs in the background, collecting and sending data to attackers.
-

4. What are the preventions used in rootkits?

- **Rootkit Prevention:** Rootkits are difficult to detect because they operate at a system level, hiding their presence. To prevent rootkits:
 1. **Use Antivirus Software:** Employ anti-malware programs that can detect and remove rootkits.
 2. **Regular Software Updates:** Keep operating systems and software up to date to patch known vulnerabilities.
 3. **Use HIDS (Host Intrusion Detection Systems):** These tools can detect suspicious system behaviors that may indicate a rootkit.
 4. **Employ Integrity Checking:** Monitor system files for unauthorized changes.
 5. **Boot from Trusted Media:** Ensure that systems are booted from trusted and secure devices.
-

5. What are DNS spoofing techniques?

- **DNS Spoofing (DNS Cache Poisoning):** A technique where an attacker sends false DNS responses to a DNS resolver, thereby redirecting traffic to malicious websites.
 - **Methods of DNS Spoofing:**
 1. **Cache Poisoning:** Manipulating the DNS cache with fraudulent records, causing users to be redirected to malicious websites.
 2. **DNS Server Spoofing:** An attacker impersonates a DNS server and replies with incorrect IP addresses.
-

6. Explain protocols susceptible to sniffing.

- **Protocols susceptible to sniffing:**
 1. **HTTP (Hypertext Transfer Protocol):** Data, including passwords, are transmitted in plain text and can easily be intercepted by sniffers.
 2. **FTP (File Transfer Protocol):** Transfers data, including passwords, in clear text.
 3. **Telnet:** Transmits data, including login credentials, in an unencrypted form.

4. **POP3/IMAP:** Used for retrieving email; when unencrypted, they are vulnerable to sniffing.
 5. **SMTP (Simple Mail Transfer Protocol):** Used for sending emails; without encryption, email contents are vulnerable.
-

7. What is ARP spoofing? Explain in detail.

- **ARP Spoofing:** Also known as ARP poisoning, it is a technique where an attacker sends false Address Resolution Protocol (ARP) messages over a local network. This results in associating the attacker's MAC address with the IP address of another host on the network.
 - **Impact of ARP Spoofing:**
 - **Man-in-the-Middle Attacks (MITM):** Attackers can intercept, modify, or redirect traffic between two parties.
 - **Denial of Service (DoS):** Redirecting traffic to a non-existent address.
 - **Detection and Prevention:**
 - Static ARP entries: Manually map IP to MAC addresses.
 - Use of ARP monitoring tools: Detect ARP poisoning attempts.
-

8. Write a short note on MAC flooding.

- **MAC Flooding:** A network attack that overloads a network switch's MAC address table with false entries. This causes the switch to fail into "fail-open" mode, where it forwards all incoming packets to every port, making it easier for attackers to sniff network traffic.
 - **Prevention:** Use port security on switches to limit the number of MAC addresses per port and enable features like DHCP snooping.
-

9. Explain how DNS attack works.

- **DNS Attack:** Attacks on the Domain Name System (DNS) to exploit weaknesses in the way domain names are resolved. Examples include DNS Spoofing, DNS Cache Poisoning, and DNS amplification attacks.
 - **Impact:**
 - **Redirection of Traffic:** Users are directed to malicious websites.
 - **Denial of Service:** Attackers can flood the DNS with queries, rendering the server unavailable.
-

10. Give different techniques of common DoS attacks.

- **Types of DoS Attacks:**
 1. **Flooding Attacks:** Overwhelm a target system with an excessive amount of traffic (e.g., SYN Flood).

2. **Resource Exhaustion:** Consuming system resources like CPU, memory, or bandwidth (e.g., Ping of Death).
 3. **Amplification Attacks:** Exploiting a third-party server to flood a target (e.g., DNS Amplification).
 4. **Teardrop Attack:** Sending malformed packets that cause the target system to crash.
-

11. Explain Smurf attack in detail.

- **Smurf Attack:** A distributed denial-of-service (DDoS) attack where an attacker sends a large number of ICMP (ping) packets with the target's IP address as the source. This results in the target being bombarded with response packets from multiple devices.
 - **Prevention:**
 - Disable IP broadcast forwarding on routers.
 - Use anti-DDoS tools and firewalls.
-

12. Differentiate between Bots and Botnets.

- **Bots:** A bot is a software application that performs automated tasks. It can be used for both legitimate purposes (e.g., web crawlers) and malicious activities (e.g., sending spam emails).
 - **Botnet:** A collection of infected bots that are controlled remotely by an attacker. They are often used to launch DDoS attacks, spread malware, or steal personal information.
-

13. Explain DoS/DDoS countermeasures.

- **DoS/DDoS Countermeasures:**
 1. **Firewalls:** Blocking malicious traffic before it reaches the target.
 2. **Intrusion Detection Systems (IDS):** Monitoring and detecting suspicious traffic.
 3. **Rate Limiting:** Limiting the number of requests a server will accept from a single source.
 4. **Load Balancing:** Distributing the traffic load across multiple servers to avoid overload.
-

14. What is spoofing? Give its types.

- **Spoofing:** The act of impersonating another entity to deceive systems or users.
- **Types of Spoofing:**
 1. **IP Spoofing:** Forging the source IP address of a packet to make it appear from a trusted source.
 2. **Email Spoofing:** Sending emails that appear to come from a trusted source to deceive recipients.
 3. **DNS Spoofing:** Manipulating DNS records to redirect users to malicious websites.

15. What are preventive measures on hijacking?

- **Preventive Measures for Hijacking:**
 1. **Secure Sessions:** Use encrypted connections (e.g., HTTPS, SSL/TLS) for secure data transfer.
 2. **Session Timeout:** Implement session expiration after a period of inactivity.
 3. **Multi-Factor Authentication (MFA):** Require multiple authentication methods for higher security.
-

16. What is hijacking? Give its types.

- **Hijacking:** The act of taking control of a legitimate user's session or device without authorization.
 - **Types of Hijacking:**
 1. **Session Hijacking:** Taking control of an active user session to gain unauthorized access.
 2. **DNS Hijacking:** Redirecting DNS queries to malicious servers to alter the user's internet browsing.
 3. **Browser Hijacking:** Modifying a user's web browser settings without consent.
-

17. Explain the difference between spoofing and hijacking.

- **Spoofing:** Impersonating a legitimate entity to deceive or mislead a victim.
 - **Hijacking:** Taking control of a session or network resource without the user's consent.
-

18. Explain sniffing countermeasures.

- **Sniffing Countermeasures:**
 1. **Encryption:** Encrypt sensitive data in transit (e.g., use HTTPS for web traffic).
 2. **VPNs:** Use Virtual Private Networks to secure network traffic.
 3. **Secure Network Protocols:** Use secure versions of protocols like SSH instead of Telnet, and HTTPS instead of HTTP.
-

19. What is a web server? Explain types of attacks against web servers.

- **Web Server:** A server that hosts websites and serves content over the internet using HTTP/HTTPS protocols.
- **Types of Attacks against Web Servers:**
 1. **SQL Injection:** Injecting malicious SQL queries to manipulate the database.

2. **Cross-Site Scripting (XSS):** Injecting malicious scripts into webpages viewed by others.
 3. **Denial of Service (DoS):** Overloading the server to make it unavailable.
-

20. Explain patch management techniques.

- **Patch Management:** The process of managing software updates or patches to fix known vulnerabilities.
 - **Techniques:**
 1. **Automated Patching:** Use automated tools to apply patches.
 2. **Testing Patches:** Test patches on non-production systems before deployment.
 3. **Regular Scheduling:** Schedule regular patch cycles to ensure up-to-date software security.
-

21. Write steps for web server hardening.

- **Web Server Hardening Steps:**
 1. **Remove Unnecessary Services:** Disable unnecessary modules and services.
 2. **Update Regularly:** Ensure the web server software is always up-to-date with security patches.
 3. **Use HTTPS:** Secure all communications with SSL/TLS.
 4. **Limit User Permissions:** Give minimal access permissions to users.
 5. **Firewall Configuration:** Set up a firewall to limit traffic to the server.
-

22. What is vulnerability, explain web server vulnerabilities.

- **Vulnerability:** A weakness in a system that can be exploited to gain unauthorized access or cause harm.
- **Web Server Vulnerabilities:**
 1. **Outdated Software:** Unpatched web server software can be exploited by attackers.
 2. **Misconfiguration:** Improper settings can expose sensitive data.
 3. **SQL Injection:** Vulnerabilities in web applications that interact with databases.

UNIT 3

1. What is web application? Explain the vulnerabilities in web application.

- **Web Application:** A web application is software that runs on a web server and interacts with users via a web browser. It processes data, stores information, and provides services to users over the internet.

- **Vulnerabilities in Web Applications:**
 1. **SQL Injection:** Attackers insert malicious SQL code to manipulate databases.
 2. **Cross-Site Scripting (XSS):** Malicious scripts are injected into web pages viewed by users.
 3. **Cross-Site Request Forgery (CSRF):** Exploits the trust that a site has in a user's browser.
 4. **Broken Authentication:** Weak or improperly implemented authentication mechanisms.
 5. **Insecure Direct Object References (IDOR):** Allows unauthorized access to objects (files, database records).
 6. **Sensitive Data Exposure:** Insufficient encryption of sensitive data like passwords.
-

2. What are the phases of web application hacking?

- **Phases of Web Application Hacking:**
 1. **Reconnaissance:** Gathering information about the target (e.g., domain names, IP addresses).
 2. **Scanning and Enumeration:** Identifying potential vulnerabilities through tools like Nmap.
 3. **Gaining Access:** Exploiting vulnerabilities like SQL injection or XSS.
 4. **Maintaining Access:** Creating backdoors or using malware to maintain access.
 5. **Clearing Traces:** Deleting logs and traces of the attack to cover up the activity.
-

3. Define web application threats and its types.

- **Web Application Threats:** Threats refer to potential events or actions that could compromise the security, functionality, or availability of a web application.
 - **Types of Web Application Threats:**
 1. **Malicious Users:** Attackers with malicious intent (hackers, competitors).
 2. **Insecure Data Storage:** Weak or unprotected storage mechanisms for sensitive data.
 3. **Session Hijacking:** Taking control of an active user session.
 4. **Cross-Site Scripting (XSS):** Injecting malicious scripts to exploit vulnerabilities.
 5. **SQL Injection:** Manipulating the application's database via insecure code.
 6. **Denial of Service (DoS):** Overloading a server to prevent service access.
-

4. Define term:

- **A. Threats:** Potential causes of an unwanted impact that could exploit a vulnerability, leading to harm or loss.
- **B. Malware:** Malicious software designed to harm or exploit systems. It includes viruses, worms, ransomware, and spyware.
- **C. Phishing:** A type of cyber attack where attackers impersonate legitimate entities to trick users into revealing personal or financial information.

5. What is Google hacking?

- **Google Hacking:** The practice of using advanced Google search operators to find vulnerabilities in websites or access sensitive information that is not meant to be publicly available. For example, searching for exposed files or directories using specific queries like `filetype:pdf`.
-

6. What are countermeasures to prevent web application vulnerabilities?

- **Countermeasures to Prevent Web Application Vulnerabilities:**
 1. **Input Validation:** Ensure all user input is validated, sanitized, and escaped to prevent injection attacks.
 2. **Use HTTPS:** Encrypt data in transit to protect sensitive information.
 3. **Implement Strong Authentication:** Use multi-factor authentication (MFA) and enforce strong password policies.
 4. **Regular Security Audits:** Regularly audit the code and configuration for vulnerabilities.
 5. **Patch Management:** Regularly update software and apply security patches.
 6. **Cross-Site Scripting (XSS) Protection:** Sanitize output to prevent malicious scripts from executing.
 7. **SQL Injection Prevention:** Use parameterized queries and stored procedures.
-

7. Define term password hacking and what are web-based cracking techniques?

- **Password Hacking:** The process of trying to guess or crack a password using various techniques.
 - **Web-based Cracking Techniques:**
 1. **Brute Force Attack:** Trying all possible combinations of passwords until the correct one is found.
 2. **Dictionary Attack:** Using a prearranged list of common passwords to guess the target's password.
 3. **Phishing:** Tricking users into revealing their passwords via fake login pages.
 4. **Credential Stuffing:** Using previously leaked usernames and passwords to access other accounts.
-

8. Define term authentication and its types.

- **Authentication:** The process of verifying the identity of a user or system.
- **Types of Authentication:**
 1. **Password-based Authentication:** Verifying identity using a password.
 2. **Biometric Authentication:** Using physical traits (fingerprints, retina scans) to verify identity.

3. **Two-Factor Authentication (2FA):** Requires two forms of identification, such as a password and a one-time code sent via SMS.
 4. **Token-based Authentication:** Using a token (e.g., a hardware device or software app) for verification.
-

9. What is password cracking and name tools used in password cracking?

- **Password Cracking:** The process of attempting to discover or recover passwords from data, through various techniques such as brute-force or dictionary attacks.
 - **Tools Used:**
 1. **John the Ripper:** A powerful password cracking tool.
 2. **Hydra:** A popular tool for password cracking in network services.
 3. **Aircrack-ng:** Used for cracking Wi-Fi passwords.
-

10. Define SQL injection and name its types.

- **SQL Injection (SQLi):** An attack where attackers exploit vulnerable SQL queries to manipulate databases.
 - **Types of SQL Injection:**
 1. **In-band SQLi:** The attacker extracts data using the same communication channel (e.g., Union-based SQLi).
 2. **Blind SQLi:** No data is returned, but the attacker is able to infer information based on the server's response (e.g., Boolean-based Blind SQLi).
 3. **Out-of-Band SQLi:** Attackers use different channels (e.g., sending data via DNS or HTTP requests).
-

11. Define vulnerabilities in SQL server.

- **SQL Server Vulnerabilities:**
 1. **SQL Injection:** Allowing untrusted input to be included in SQL queries.
 2. **Improper Permissions:** Insufficient security measures on SQL server permissions, allowing unauthorized access.
 3. **Outdated Software:** Failing to apply patches to SQL server software, which can leave it vulnerable to known exploits.
-

12. What is buffer overflow explain its types?

- **Buffer Overflow:** A vulnerability where more data is written to a buffer than it can hold, causing the overflow to overwrite adjacent memory, which can lead to system crashes or code execution.
- **Types:**

1. **Stack-based Buffer Overflow:** Happens in the call stack and can lead to the execution of arbitrary code.
 2. **Heap-based Buffer Overflow:** Occurs in the heap area and can corrupt data used by programs.
-

13. Define stack-based buffer overflow.

- **Stack-based Buffer Overflow:** This occurs when data overflows from a buffer located on the call stack, potentially overwriting the return address of a function and allowing the attacker to control program execution.
-

14. Define term mutation in EH and explain mutation techniques.

- **Mutation in Ethical Hacking (EH):** Refers to changing or modifying an attack's signature or pattern to evade detection by security systems.
 - **Mutation Techniques:**
 1. **Encoding:** Encoding malicious payloads to evade detection by antivirus programs.
 2. **Polymorphism:** Changing the structure of malicious code each time it is executed.
 3. **Obfuscation:** Making code harder to understand or analyze while maintaining its functionality.
-

15. Explain WEP in detail.

- **Wired Equivalent Privacy (WEP):** An outdated wireless security protocol designed to provide a level of security equivalent to wired networks.
 - **Limitations:**
 - Weak encryption (RC4) and easily broken by modern tools.
 - Vulnerable to key recovery attacks like the FMS attack.
-

16. Write different ways to accomplish wireless hacking.

- **Ways to Hack Wireless Networks:**
 1. **WEP Cracking:** Using tools like Aircrack-ng to break WEP encryption.
 2. **WPA/WPA2 Cracking:** Using brute force or dictionary attacks to guess the password for WPA or WPA2.
 3. **Evil Twin Attack:** Setting up a fake access point to intercept data from unsuspecting users.
 4. **Packet Sniffing:** Using tools like Wireshark to capture network traffic and analyze it for sensitive data.
-

17. Explain Wired Equivalent Privacy in detail.

- **Wired Equivalent Privacy (WEP):** A security protocol for wireless networks that was designed to provide a level of security equivalent to that of a wired network.
 - **Issues with WEP:**
 - Weak encryption and easily cracked using modern tools.
 - Vulnerable to attacks such as IV (Initialization Vector) collision attacks and dictionary-based attacks.
-

18. Explain WPA Authentication Mechanism.

- **WPA (Wi-Fi Protected Access):** A security protocol designed to replace WEP and provide stronger data protection for wireless networks.
 - **Authentication Mechanism:**
 - **WPA-PSK (Pre-Shared Key):** Uses a shared password for authentication.
 - **WPA-Enterprise:** Uses a centralized RADIUS server for more robust authentication, ideal for enterprise networks.
-

19. Explain in detail Wireless Sniffing and its working.

- **Wireless Sniffing:** The process of intercepting and analyzing wireless network traffic.
 - **Working:**
 - Attackers use sniffing tools like Wireshark to capture packets from the wireless network.
 - They can analyze the captured packets for sensitive information like passwords, session cookies, or unencrypted data.
-

20. Define the term Rogue Access Point and explain its working.

- **Rogue Access Point:** An unauthorized access point set up within a network to intercept traffic or compromise the network.
 - **Working:**
 - The attacker sets up a rogue AP with the same SSID as a legitimate AP.
 - Unsuspecting users connect to the rogue AP, allowing the attacker to intercept or manipulate their data.
-

21. Explain penetration testing methodology.

- **Penetration Testing Methodology:**
 1. **Reconnaissance:** Gathering information about the target system.
 2. **Scanning and Enumeration:** Identifying open ports, services, and vulnerabilities.
 3. **Exploitation:** Trying to exploit vulnerabilities to gain access.

4. **Post-Exploitation:** Maintaining access, exploring further, and gathering sensitive data.
 5. **Reporting:** Documenting findings and providing recommendations for remediation.
-

22. Write short note on pen test deliverables.

- **Pen Test Deliverables:**
 1. **Executive Summary:** A high-level summary of findings and risk impact.
 2. **Detailed Report:** A comprehensive document detailing the vulnerabilities, exploits, and recommended mitigations.
 3. **Remediation Plan:** A set of action items for improving security based on the findings.
-

23. Explain automated tools used in penetration testing.

- **Automated Tools for Pen Testing:**
 1. **Nmap:** Network discovery and vulnerability scanning.
 2. **Nessus:** Vulnerability scanner to identify potential flaws in a network.
 3. **Burp Suite:** Web vulnerability scanner for testing web applications.
 4. **Metasploit:** A framework for exploiting vulnerabilities and conducting penetration tests.
-

24. Explain steps to secure wireless networks.

- **Steps to Secure Wireless Networks:**
 1. **Use WPA3:** Choose WPA3 encryption over older protocols like WEP or WPA.
 2. **Change Default SSID:** Avoid using default network names.
 3. **Enable MAC Address Filtering:** Restrict network access to specific devices.
 4. **Use Strong Passwords:** Enforce strong, complex passwords for Wi-Fi networks.
 5. **Disable SSID Broadcasting:** Hide the network name to make it less visible to attackers.
 6. **Regularly Update Firmware:** Keep router firmware up to date to fix security vulnerabilities.